

## Requisitos Não Funcionais – Gateway PAVPLAS

| ID     | Categoria               | Requisito Não Funcional                                                                                                                                                    |
|--------|-------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| RNF-01 | Desempenho              | O sistema deve responder às operações críticas de pagamento em até 3 segundos em pelo menos 95% das requisições, considerando as operações sob responsabilidade da própria |
| RNF-02 | Desempenho              | Após o recebimento de uma confirmação do provedor, a atualização do status no sistema deve ocorrer em até 10 segundos em 95% dos casos.                                    |
| RNF-03 | Disponibilidade         | O sistema deve possuir disponibilidade mensal mínima de 99,5%, desconsiderando períodos de manutenção previamente programados.                                             |
| RNF-04 | Segurança               | Toda comunicação entre cliente, aplicação, serviços internos e integrações externas deve utilizar HTTPS/TLS.                                                               |
| RNF-05 | Segurança               | As senhas devem ser armazenadas utilizando mecanismos de hash adequados, nunca em texto                                                                                    |
| RNF-06 | Segurança               | O sistema deve limitar tentativas de autenticação e possuir mecanismo seguro de recuperação                                                                                |
| RNF-07 | Segurança               | Usuários internos que executem operações críticas devem utilizar autenticação multifator.                                                                                  |
| RNF-08 | Autorização             | O sistema deve aplicar controle de acesso baseado em perfis e menor privilégio, validado no                                                                                |
| RNF-09 | Privacidade             | Cada cliente deve ter acesso somente aos seus próprios dados, pedidos, pagamentos e                                                                                        |
| RNF-10 | Proteção de dados       | O sistema não deve armazenar dados completos e sensíveis do cartão de crédito, utilizando tokenização ou mecanismo equivalente fornecido pelo provedor.                    |
| RNF-11 | Segurança de integração | Webhooks devem possuir mecanismos de autenticação/assinatura e proteção contra eventos falsificados ou repetidos.                                                          |
| RNF-12 | Confiabilidade          | A repetição de uma mesma solicitação não pode resultar em uma cobrança, baixa de estoque ou expedição duplicada.                                                           |
| RNF-13 | Integridade             | Os pedidos devem seguir estados válidos, não permitindo que um pedido avance para expedição sem o cumprimento das etapas obrigatórias.                                     |
| RNF-14 | Segurança               | Chaves de API, certificados e demais segredos não devem ser armazenados diretamente no                                                                                     |
| RNF-15 | Segurança de API        | A API deve validar autenticação, autorização, formato, tamanho e conteúdo dos dados                                                                                        |
| RNF-16 | Proteção contra ataques | O sistema deve possuir mecanismos de proteção contra injeção, XSS, CSRF, força bruta, abuso de endpoints e uploads maliciosos, quando aplicáveis.                          |
| RNF-17 | Auditoria               | O sistema deve registrar eventos relevantes, como autenticações, alterações de pedidos, alterações de preços, pagamentos, webhooks, estornos e integrações.                |
| RNF-18 | Proteção de logs        | Os registros de auditoria devem impedir alteração indevida e não devem expor senhas, tokens ou dados financeiros sensíveis.                                                |

|        |                    |                                                                                                                                                                           |
|--------|--------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| RNF-19 | Monitoramento      | O sistema deve gerar alertas para falhas relevantes, como repetição de login, falhas de webhook e divergências financeiras.                                               |
| RNF-20 | Backup             | Os dados de pedidos e pagamentos devem possuir backup periódico e procedimento de restauração testado.                                                                    |
| RNF-21 | Recuperação        | A solução deve possuir meta de RPO de até 24 horas e RTO de até 4 horas.                                                                                                  |
| RNF-22 | Resiliência        | Integrações externas devem possuir timeout, tentativas controladas e mecanismos para lidar com indisponibilidade temporária.                                              |
| RNF-23 | Escalabilidade     | A aplicação deve suportar pelo menos 100 solicitações simultâneas no ambiente definido para teste, com taxa de erro inferior a 1%.                                        |
| RNF-24 | Usabilidade        | A interface deve funcionar adequadamente em dispositivos móveis e computadores, apresentando mensagens claras de erro e confirmação.                                      |
| RNF-25 | Privacidade / LGPD | O sistema deve coletar somente os dados necessários para suas finalidades e controlar o compartilhamento com provedores de pagamento, serviços fiscais e transportadoras. |
| RNF-26 | Retenção           | Dados, documentos, comprovantes e logs devem possuir política de retenção e descarte compatível com as necessidades operacionais e obrigações legais.                     |
| RNF-27 | Manutenibilidade   | O desenvolvimento deve incluir revisão de código, análise de dependências, testes e tratamento de vulnerabilidades antes da disponibilização em produção.                 |